

Part 3. Human-Centred Security

Sam Rutherford
2001832

1. Introduction

Correctly enforced cybersecurity regulations and principles are critically important to a company's wellbeing as the cost of cybercrime is estimated to increase to \$10.5 trillion by 2025 (Intrusion Inc., 2020), meaning that companies should aim to greatly increase their cyber resilience within the coming years. ScottishGlen, a Scottish energy company has recently had employees reporting phishing emails which are believed to be from hackers who are attempting to compromise the company's network and cause great financial damage. Phishing attacks are also the most common type of cyber-attack which a company will be victim to, comprising of 57% of total cyberattacks (McLean, 2024).

This report will aim to cover the various human centred risks and recommendations and suggest an authentication design for a sign-up page for Scottish Glen's employees to use based upon prior literature review.

2. Human centred risks

To understand the human centred risks which are imposed by the cyber-attacks orchestrated by the hackers towards ScottishGlen, understanding phishing attacks is essential. Phishing attacks involve tricking the victim into clicking either a link or attachment that they believe is trustworthy but is malicious and can cause harm to their network by giving away credentials or installing malware in extreme cases. This is commonly achieved through emails which are sent to the victim.

A flowchart for how phishing emails can be created is shown below:

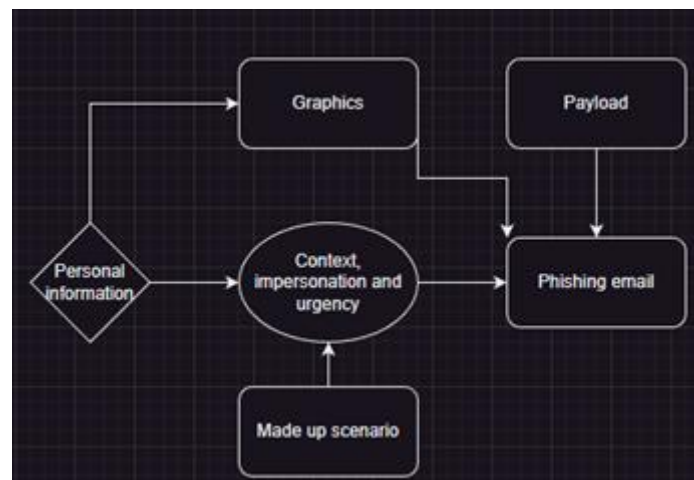


Figure 1. Flowchart displaying the methodology of how phishing emails are created.

The phishing email generation flowchart can be broken down into several key components:

- Personal information is utilised by the phishing email creator to help develop a more convincing email. A spear phishing attack will aim to utilise this personal information about the victim which is commonly gathered through their social media profiles.
- The made-up scenario is fictitious but when combined with the personal information accumulated about the victim, the phishing email will contain context and urgency.
- This context and urgency are utilised to pressure the victim into clicking or downloading the payload which is the goal of the phishing attack.

One paper (Alkhali, Hewage, Nawaf, & Khan, 2021) claims that cyber criminals aim to exploit numerous aspects of an employee for a phishing attack, which can all be attributed to human nature. An employee's lack of cyber ethics, which can be viewed as general laziness for maintaining good cybersecurity principles (which a company should be enforcing), would be something the phisher would aim to exploit. Laziness when following cybersecurity guidelines is somewhat inevitable due to a balance of maintaining security and breaking habits of the employees where cyber security is not paramount, which another paper (Shropshire, Warkentin, & Sharma, 2015) also suggests. For example, many companies suggest regularly rotating strong passwords, but it is common for employees to 'forget' or not bother due to inherent habits and laziness. However, the employee should not be held responsible due to the cybersecurity guidelines enforced by the security team being too strict and unrealistic. Additionally, if the employee who is a victim to the phishing email is unable to identify what a phishing email is, this is also a fault of the company for not giving comprehensive, regular, and up to date instructions on how to identify phishing attempts.

3. Human centred recommendations

In order to minimise the human centred risks, establishing certain recommendations for ScottishGlen to follow must be suggested. A Paper (Parno, Kuo, & Perrig, 2006) identifies the critical issue of putting too much reliance of users and should aim to cut the human out of the picture as much as possible and reduce human involvement. While it is undeniable that most phishing attacks are due to a human flaw and taking them out of the scenario would severely reduce the amount of successful phishing attacks, it is impossible to do so due to human employees being essential to operations of any company. Another paper (Marchal, et al., 2017) suggested using phishing detection tools to automatically detect if an email appeared to be suspicious:

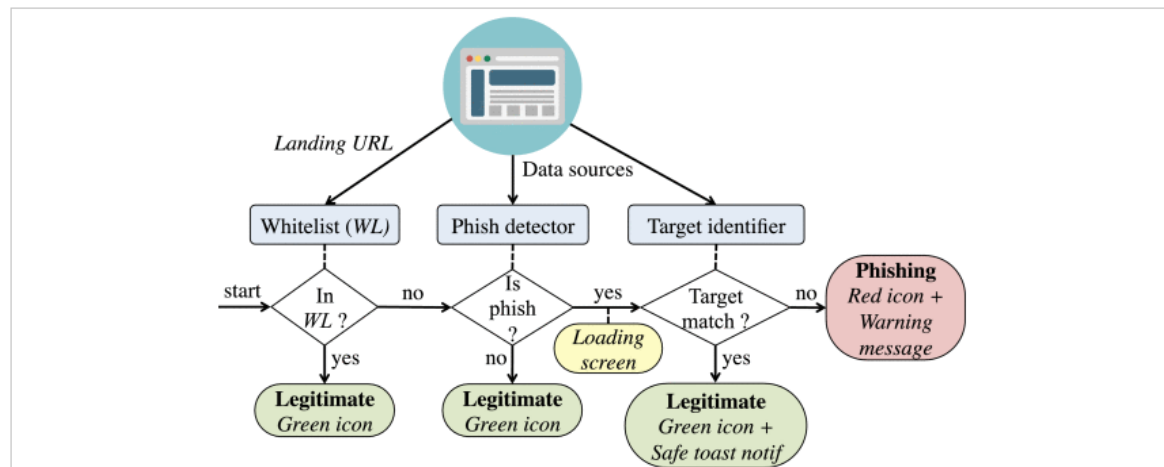


Figure 2. Flowchart displaying Off-the-Hook phishing detection (Marchal, et al., 2017)

Figure 2 displays the decision flow chart for the tool suggested by the paper (known as 'Off-the-Hook') which would determine the safety of a URL which a recipient had been sent. The URL within the email undergoes several checks to discern if it is a phishing attempt or not with firstly the tool using a local whitelist which will immediately verify the email as safe due to it already being registered as known and no further investigation into the URL takes place. The next step involves the contents of the web page being analysed which undergoes extensive checks to determine if the URL is safe before indicating to the user with a colour coded response (green for safe, red for warning/phishing).

4. Authentication mechanisms

Authentication is a critically important method for only allowing verified users to access infrastructure of a company. For authentication to work, usernames and passwords are required to uniquely identify and verify the user. Notably, the password must have some attachment to the user physically or mentally to allow for memorability and/or security. Authentication methods can be broken down into three different types of having attachment to the individual of the account, something you know, something you have and something you are. Table 1 displays various authentication methods separated by their model:

Table 1. Table describing the different types of authentications (Barkadehi, Nilashi, Ibrahim, Fardi, & Samad, 2018).

Ownership model	Knowledge-based model	Inherent-based model
1. Physical keys	1. Passwords	1. Fingerprints
2. Smart card	2. PIN code	2. Palm
3. NFC	3. Lock pattern	3. Iris
4. RFID	4. Graphical password	4. Voices
5. Hardware-token	5. Rhyme based	5. Gestures
6. Cell-phone	6. Challenge response	6. Face

Something you know is what is the most common form of authentication, being passwords, pin codes and other forms of things you must remember in order to authenticate yourself. While it may appear to be simple to create a password, creating a secure one is essential to avoid it being a victim to password attacks, such as a dictionary attack, which involves using a wordlist (typically of very common passwords) or brute forcing which will attempt every character combination (onelogin, n.d.). Paper (Barkadehi, Nilashi, Ibrahim, Fardi, & Samad, 2018) covered numerous alternative methods for performing 'something you know' authentication attempt by other papers. One of these methods by Gokhale and Waghmare (2016) attempted to be different to typical password authentication by utilising memory or graphical means of verifying a user's identity. This was found to be an effective way of preventing shoulder surfing and keyloggers.

Regarding something you have, these are the most ancient forms of authentication as simple physical keys are still used to restrict and verify someone entry to a physical place. A more up-to-date version of physical keys would be a key fob, which acts as a hardware token which can be programmed to send a coded radio signal through the radio frequency identification (RFID) chip (Awati, n.d.). The encoded RFID signal is unique, resulting in the fob only working for one 'lock' but multiple fobs with the same RFID can open the same 'lock' which would be useful in a company with many employees. Another authentication method which utilises something a user would have would be 2 factor authentication and one-time passwords/passcodes on a mobile/cell phone. What this achieves is requiring something that is currently in possession of the user (the phone) being used to verify their identity. If a hacker has the user's credentials and attempts to login, they would be met with a pop up requiring an OTP which the hacker would most likely not have access to, stopping the unauthorised login attempt.

The something you are, or 'Inherent-based model' as seen in table 1 relies typically on biometrics, which makes something completely unique to yourself. Examples of the biometrics which are commonly used include fingerprint identification, which was used in phones such as the iPhone models between 6 and 11. This was used to log into the iPhone. Later, Apple would discontinue using fingerprint biometrics and opt instead to rely on facial recognition for identification which not only was used for not only logging into the iPhone but also to manage credentials of other accounts. For example, a user with setup facial ID could automatically have their saved passwords filled out after successfully passing a facial ID check. Additionally, many banking and payment methods are authorised using facial ID. Notably this was not possible with fingerprint ID suggesting Apple's belief that facial ID authorisation is significantly more secure. An interesting uniqueness of biometric authentication compared to passwords would be that faces and fingerprints are not kept secret, unlike passwords where secrecy is essential.

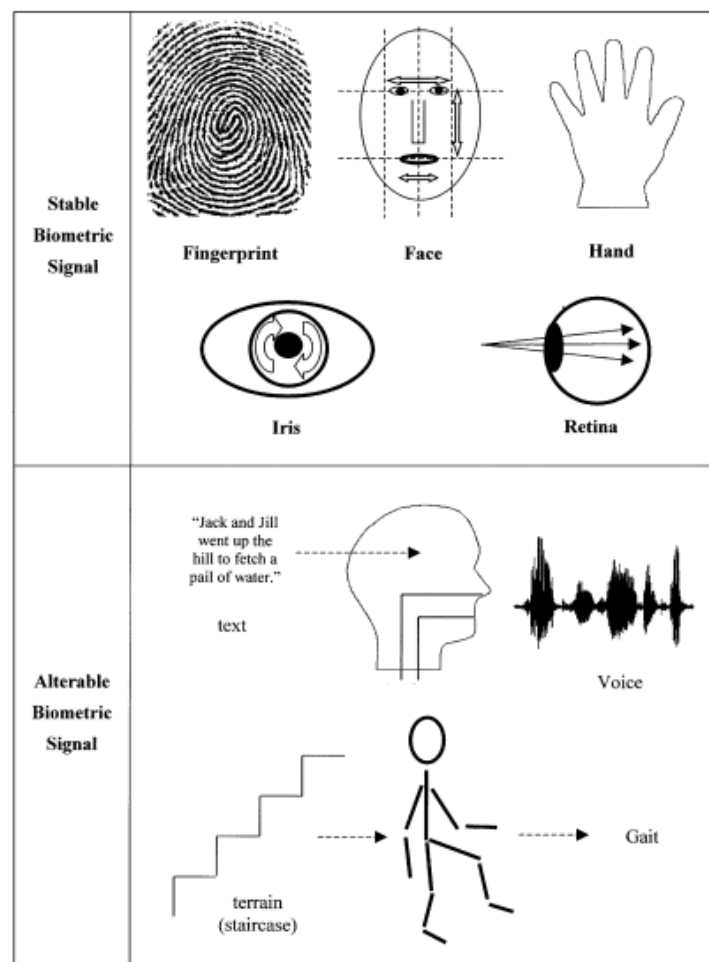


Figure 3. Displaying the differences between stable and alterable biometric signals (O'Gorman, 2003).

One paper (O'Gorman, 2003) differentiates stable and alterable biometric data, for example the previously discussed fingerprint and facial ID would be considered as stable due to not being able to easily change. Compare this to voice recognition or gestures which develop and change overtime subconsciously without the individual realising. This change could result in the authentication failing, at technically no fault of the user.

5. Authentication recommendations

To develop a suitable authentication mechanism to be used by employees of Scottish Glen, research and literature review of what makes an effective account creation system had to be performed. The type of authentication mechanism being chosen for this task was the 'something you know' or knowledge-based model, i.e. utilising a username and password system. A Paper (Summers & Bosworth, 2004) explains the numerous hardships of developing an authentication system for employees. To account for usability, guidance on generating an effective password is critically important as often without it, employees will pick passwords based on themselves, celebrities they enjoy or their favourite hobbies. This carelessness can lead to the user being victim to social engineering attacks and thus potentially compromising the entire company network. While an automated method of detecting poor passwords which included the users own hobbies would be hard/impossible to implement, paper (Shay, et al., 2016) suggests utilising a blacklist for extremely common passwords. This blacklist would detect poor substrings within passwords such as '1234, password' etc, in an effort to strengthen the password from a dictionary attack. Using this method would have prevented 12.5% of the passwords within the Yahoo data leak from being created. This method for using a blacklist could be adapted to block any attempts where the user would try to put their own personal information, such as name and email address to reduce the risk of it being vulnerable to a social engineering attack.

Paper (Summers & Bosworth, 2004) also suggests other guidelines for users creating their passwords. The most notable suggestions include a minimum length of 10 characters, as increasing the length of the password makes it less susceptible to brute forcing attacks. The use of including at least one number, special character and upper-case character is done to further the passwords obscurity, reducing the risk of it being victim to a dictionary attack. Notably the paper also mentions that users should be creative in how where within the password they place the special characters or numbers as users commonly and lazily just add these at the end of their password. Hackers would be aware of this and adapt their dictionary attack to include these adaptations. With these considerations a wireframe diagram for an account creation page was created. Note that the account creation form is partially completed:

Sign Up

https://www.scottishglen/signup.com

Sign up page

Scottish Glen logo

Email address
johndoe@gmail.com

Username
JohnTheDude

Password
••••••••••

Confirm password

Create account

Password requirements

- Password must be between 10 and 30 characters
- Must contain at least one upper and lower case character
- Must contain at least one number
- Must contain at least one special character
- Try to avoid using common passwords
- Try to avoid using your own name or name of the website

Figure 4. Wireframe diagram of the proposed account creation page.

The wireframe in figure 4 contains design considerations based on the literature review and research performed:

- The password recommendations based on the prior papers discussed were utilised. Additionally, an upper limit of password characters was introduced. While no limit was suggested by a paper, the upper limit acts to prevent users from making unnecessarily long passwords which could cause technical errors or cause the user to forget the password due to its length.
- A password substring blacklist would be implemented. This would aim to prevent strong (meets the password requirements) but contains extremely common password substrings such as 'password'. This would also be implemented to disallow substrings containing the user's name or to do with the company.
- The text would below 'Password requirements' would change from red to green once one of the password requirements is fulfilled. This is to guide the user into creating a secure password and helping them to understand what can be done to improve their password.
- Password must be repeated in the 'Confirm password' field which verifies the user knows their password.

- A future implementation which was not included due to being too complex to accurately display in the wireframe would be a strength scoring system where a password's strength would be given a score based on how effectively it meets the password requirements. This would have to be comprehensively researched and evaluated due to certain requirements having more value than others, such as password length.

References

- Alkhali, Z., Hewage, C., Nawaf, L., & Khan, I. (2021). Phishing Attacks: A Recent Comprehensive Study and a New Anatomy. *Front. Comput. Sci.* Retrieved from <https://www.frontiersin.org/articles/10.3389/fcomp.2021.563060/full>
- Awati, R. (n.d.). *Key fob*. Retrieved from TechTarget: <https://www.techtarget.com/searchsecurity/definition/key-fob>
- Barkadehi, M. H., Nilashi, M., Ibrahim, O., Fardi, A. Z., & Samad, S. (2018). Authentication systems: A literature review and classification. *Telematics and Informatics* (pp. Pages 1491-1511). ScienceDirect. Retrieved from <https://www.sciencedirect.com/science/article/abs/pii/S0736585318301400>
- Intrusion Inc. (2020, November 18). *Cybercrime To Cost The World \$10.5 Trillion Annually By 2025*. Retrieved from GlobeNewswire: <https://www.globenewswire.com/news-release/2020/11/18/2129432/0/en/Cybercrime-To-Cost-The-World-10-5-Trillion-Annually-By-2025.html>
- Marchal, S., Armano, G., Gröndahl, T., Saari, K., Singh, N., & Asokan, N. (2017). Off-the-Hook: An Efficient and Usable Client-Side Phishing Prevention Application. *IEEE Transactions on Computers*, 1717-1733. Retrieved from <https://ieeexplore.ieee.org/abstract/document/7926371>
- McLean, M. (2024, January 4). *2024 Must-Know Cyber Attack Statistics and Trends*. Retrieved from Embroker: <https://www.embroker.com/blog/cyber-attack-statistics/>
- O'Gorman, L. (2003). Comparing passwords, tokens, and biometrics for user authentication. *Proceedings of the IEEE*, 2021-2040. Retrieved from <https://ieeexplore.ieee.org/abstract/document/1246384>
- onelogin. (n.d.). *Six Types of Password Attacks & How to Stop Them*. Retrieved from onelogin: <https://www.onelogin.com/learn/6-types-password-attacks>
- Parno, B., Kuo, C., & Perrig, A. (2006). Phoolproof Phishing Prevention. *Financial Cryptography and Data Security* (pp. 1-19). Berlin: Springer Berlin Heidelberg. Retrieved from https://link.springer.com/chapter/10.1007/11889663_1
- Shay, R., Komanduri, S., Durity, A. L., Huh, P., Mazurek, M. L., Segreti, S. M., . . . Cranor, L. F. (2016). Designing Password Policies for Strength and Usability. *ACM Transactions on Information and System Security* Volume 18, Issue 4 (pp. 1-34). ACM. Retrieved from <https://dl.acm.org/doi/epdf/10.1145/2891411>
- Shropshire, J., Warkentin, M., & Sharma, S. (2015). Personality, attitudes, and intentions: Predicting initial adoption of information security behavior. *Computers & Security*, 177-191. Retrieved from <https://www.sciencedirect.com/science/article/pii/S0167404815000036>
- Summers, W., & Bosworth, E. (2004). Password policy: The good, the bad, and the ugly. 1-6. Retrieved from https://www.researchgate.net/profile/Wayne-Summers-2/publication/234799064_Password_policy_The_good_the_bad_and_the_ugly/links/54f204310cf2f9e34eff3d50/Password-policy-The-good-the-bad-and-the-ugly.pdf